

1. Ambiente operativo e obiettivi

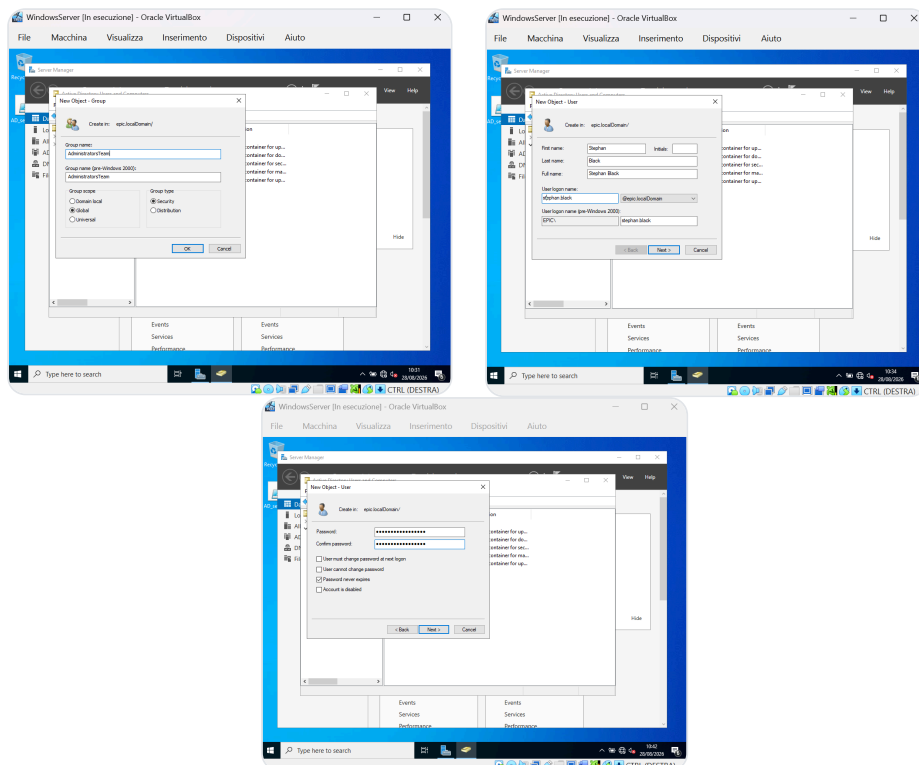
L'attività descritta nel presente report è stata eseguita all'interno di un ambiente di virtualizzazione gestito tramite l'hypervisor *Oracle VM VirtualBox*. In tale infrastruttura virtuale è stata creata e configurata un'istanza del sistema operativo Windows Server 2022 con il ruolo di Controller di Dominio (*Active Directory Domain Services*).

L'obiettivo principale dell presente report è la dimostrazione dei processi di gestione centralizzata degli utenti e dei gruppi di sicurezza all'interno del dominio. Nello specifico, le attività mirano a strutturare una corretta gerarchia organizzativa, creare e associare gli account utente, applicare il principio del minimo privilegio tramite l'assegnazione mirata delle autorizzazioni NTFS e dei criteri di gruppo (GPO), e verificare la corretta applicazione delle restrizioni di sicurezza.

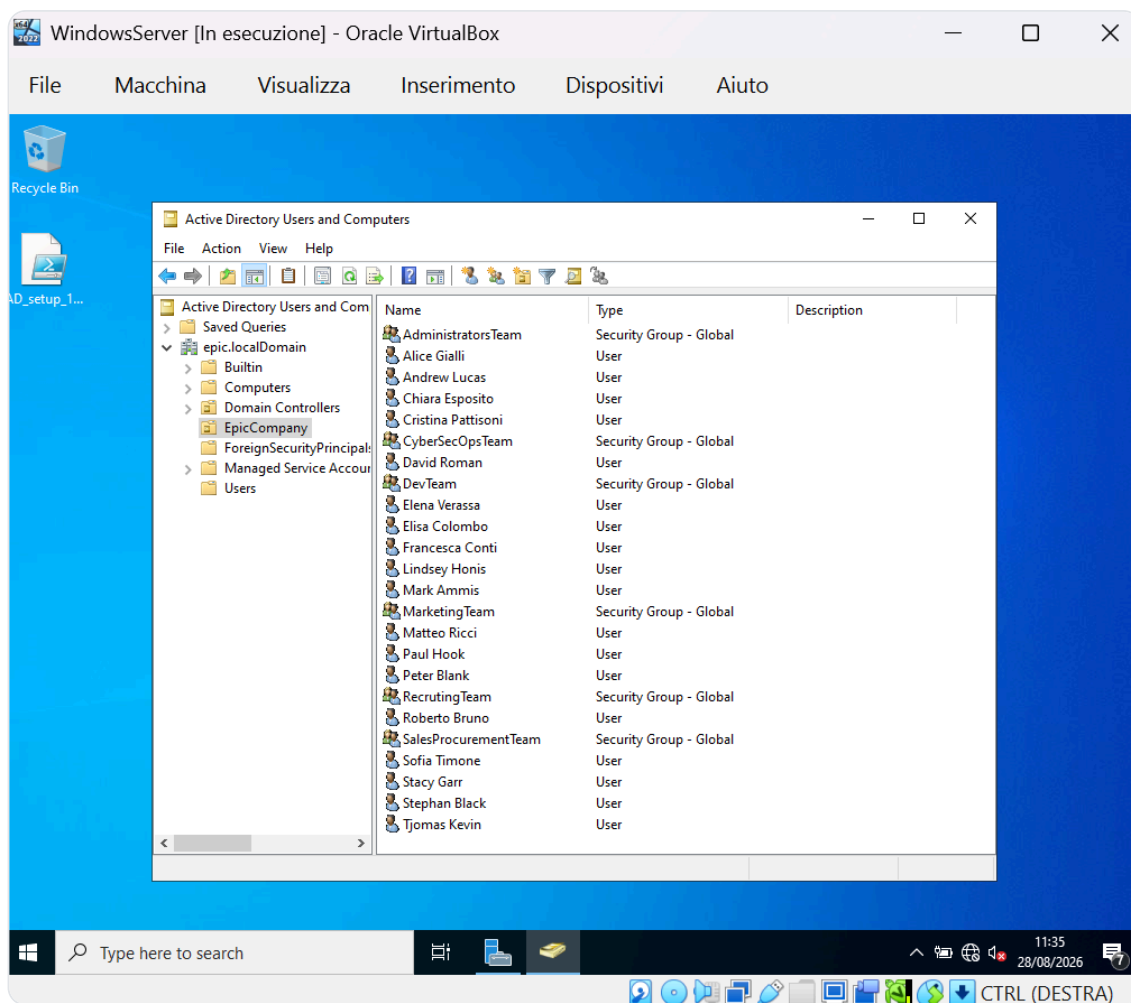
2. Creazione e configurazione dei gruppi

La procedura di popolamento dell'infrastruttura Active Directory è stata eseguita tramite la console Utenti e computer di Active Directory (*dsa.msc*), seguendo il seguente flusso di creazione di gruppi di sicurezza e account utente:

- Nella creazione del gruppo di sicurezza, all'interno del dominio `epic.localDomain`, è stato creato il gruppo di sicurezza `AdministratorsTeam`. In questa operazione sono stati impostati i parametri:
 - Group Scope* a `Global` (Consente l'assegnazione dei membri appartenenti allo stesso dominio per accedere a risorse in qualsiasi dominio della foresta).
 - Group Type* a `Security` (Abilita l'assegnazione diretta di autorizzazioni su file, cartelle e criteri di gruppo).
- Nella Configurazione dell'account utente, `stephan.black` in esempio di configurazione tipica, è stato configurato il logon name (UPN), in questo caso `stephan.black@epic.localDomain`, e lo User logon name (pre-Windows 2006), in questo caso `EPIC\stephan.black`.
- Nella impostazione dei requisiti di autenticazione, per ciascun account è stata assegnata una password complessa generata secondo la nomenclatura `<prime 3 lettere nome><prime 3 lettere cognome>.Epicpass!` (`stebla.Epicpass!` in esempio per l'utente). Inoltre, in questa attività, e nella fase di provisioning, è stata selezionata l'opzione "*Password never expires*" per gli account di servizio/amministrazione di test, deselezionando "*User must change password at next logon*".



Schermate del processo di configurazione del gruppo AD gruppo AD `AdministratorsTeam`, e di un utente previsto per questo gruppo. La password impostata segue la seguente nomenclatura: `<prime 3 lettere nome><prime 3 lettere cognome>.Epicpass!`



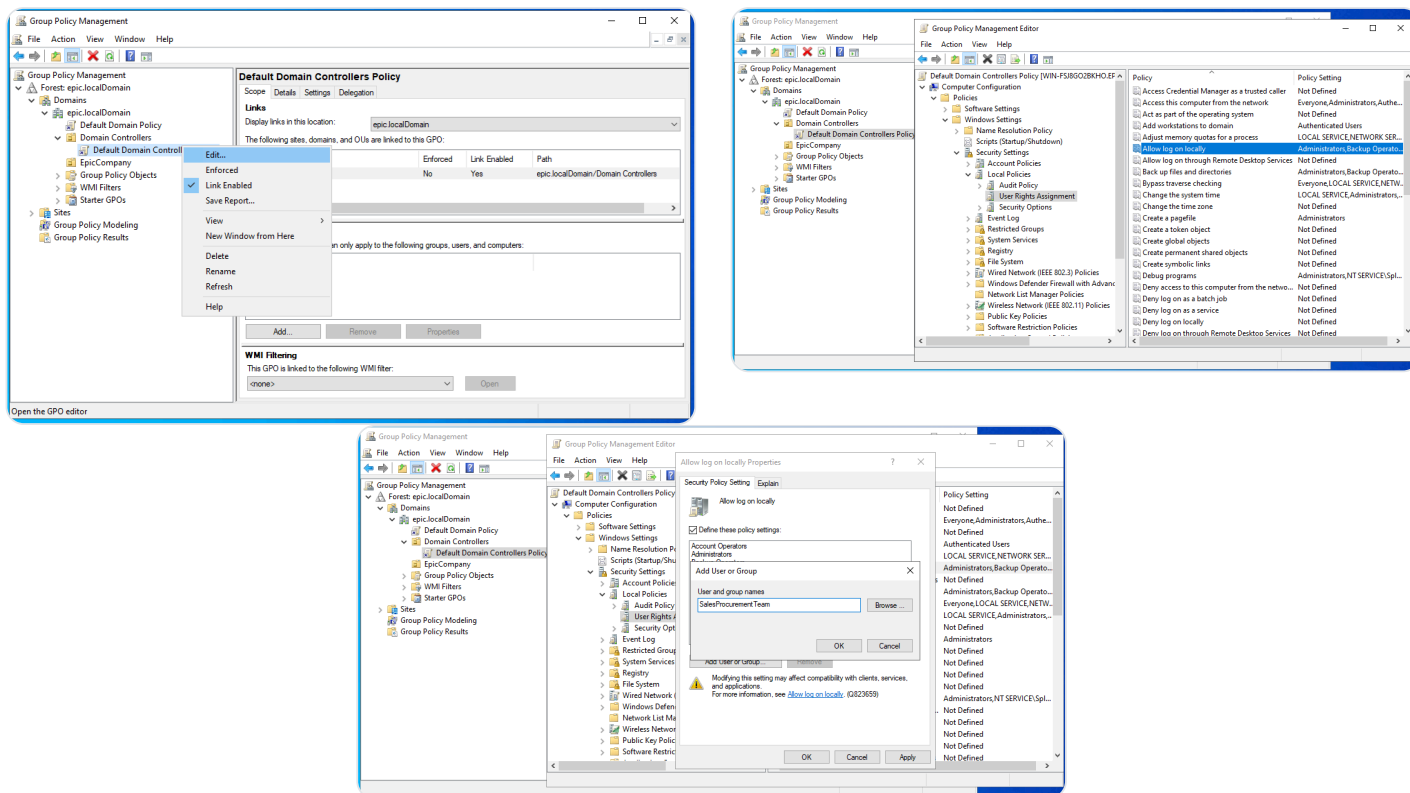
Schermata della vista della *Organizational Unit* (OU) *EpicCompany* al termine del processo di configurazione dei gruppi AD e dei relativi utenti nel pannello *Active Directory Users and Computers*

2.1. Impostazioni delle *Group Policy* per l'accesso locale

Per impostazione predefinita nei Domain Controller di Windows Server, l'autenticazione interattiva locale è riservata esclusivamente agli account con privilegi amministrativi. Al fine di consentire l'accesso diretto alla macchina virtuale da parte degli utenti appartenenti ai vari team aziendali per le relative verifiche e collaudi operativi, si è reso necessario modificare i diritti di accesso dell'infrastruttura *Active Directory*.

Attraverso la vista *Group Policy Management* (`gpmc.msc`), si sono svolte le seguenti operazioni:

- modifica della *policy* del *Domain controller*, dove, in accesso in modifica, si è acceduto in modifica alla Default Domain Controllers Policy dell'unità organizzativa `epic.localdomain`, e si è abilitata la policy "Consentire log on locale", o "Allow log on locally".
- estensione degli accessi consentiti ai gruppi della *Organizational Unit* (OU) "EpicCompany", dove nel pannello di proprietà della policy "Allow log on locally", sono stati aggiunti i gruppi esposti nel paragrafo successivo.
- applicazione dell'aggiornamento dei criteri di gruppo tramite il comando `gpupdate /force`, eseguito sul software di "linea di comando" *PowerShell*



Schermate della vista di visualizzazione delle GPO (nota come *Group Policy Management*) per l'applicazione del consenso all'accesso locale

3. Matrice di appartenenza degli utenti-gruppi AD

Di seguito viene riportata la struttura dei gruppi di sicurezza creati in Active Directory con l'elenco dei rispettivi membri associati e i relativi nomi utente (`username`)

Gruppo	Membri (Nome e Cognome)	
AdministratorsTeam	- Mark Ammis [mark.ammis] - Stephan Black [stepan.black]	Elena Verassa [elena.verrassa]
MarketingTeam	- Chiara Esposito [chiara.esposito] - David Roman [david.roman]	- Elisa Colombo [elisa.colombo] - Peter Blank [peter.blank]
DevTeam	- Paul Hook [paul.hook] - Lindsey Honis [lindsey.honis] - Stacy Garr [stacy.garr]	- Tjomas Kevin [tjomas.kevin] - Cristina Pattisoni [cristina.pattisoni]
CyberSecOpsTeam	- Tjomas Kevin [tjomas.kevin] - Paul Hook [paul.hook]	Andrew Lucas [andrew.lucas]
RecruitingTeam	- Alice Gialli [alice.galli] - Roberto Bruno [roberto.bruno]	Sofia Timone [sofia.timone]
SalesProcurementTeam	Matteo Ricci [matteo.ricci]	Francesca Conti [francesca.conti]

4. Struttura dell'albero delle cartelle

Per garantire una gestione organizzata delle risorse aziendali e l'applicazione efficiente delle autorizzazioni NTFS/SMB, è stata definita una struttura gerarchica di cartelle sul volume di dati del server (`C:\EpicOrgData`).

Ogni reparto/gruppo di lavoro dispone di una cartella condivisa dedicata, configurata secondo il principio del minimo privilegio: gli utenti hanno accesso esclusivamente alle risorse pertinenti al proprio ruolo operativo.

4.1. Albero gerarchico e mappa ACL

Per garantire una gestione organizzata delle risorse aziendali e l'applicazione efficiente delle autorizzazioni NTFS/SMB, è stata definita una struttura gerarchica di cartelle sul volume di dati del server.

A partire dalla cartella *radice* dell'albero gerarchico dei percorsi delle risorse del gruppo (OU) `EpicCompany`, assegnata al percorso

`C:\EpicOrgData`, si è definito il seguente albero gerarchico:

- `Administrators`, per il gruppo `AdministratorsTeam`
- `Marketing`, per il gruppo `MarketingTeam`
- `Development`, per il gruppo `DevTeam`
- `CyberSecOps`, per il gruppo `CyberSecOpsTeam`
- `Recruiting`, per il gruppo `RecruitingTeam`
- `SalesProcurement`, per il gruppo `SalesProcurementTeam`

Per la gestione degli accessi, è stata definita, tramite il comando `Set-Acl` nel software "di linea di comando" *PowerShell* la seguente mappa di *access control list*:

Nome della cartella	ACL del gruppo AD <code>AdministratorsTeam</code>	ACL del gruppo AD <code>MarketingTeam</code>	ACL del gruppo AD <code>DevTeam</code>	ACL del gruppo AD <code>CyberSecOpsTeam</code>	ACL del gruppo AD <code>RecruitingTeam</code>	ACL del gruppo AD <code>SalesProcurementTeam</code>
<code>Administrators</code>	Controllo Completo (<i>Full Control</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)
<code>Marketing</code>	Controllo Completo (<i>Full Control</i>)	Modifica Read/Write/Delete	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)
<code>Development</code>	Controllo Completo (<i>Full Control</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Modifica Read/Write/Delete	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)
<code>CyberSecOps</code>	Controllo Completo (<i>Full Control</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Modifica Read/Write/Delete	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)
<code>Recruiting</code>	Controllo Completo (<i>Full Control</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Modifica Read/Write/Delete	Negazione esplicita (<i>Explicit Deny</i>)
<code>SalesProcurement</code>	Controllo Completo (<i>Full Control</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Modifica Read/Write/Delete

Al termine delle operazioni di applicazione delle *Access Control List* (ACL) e la contestuale assegnazione dell'account Administrator al gruppo di sicurezza `AdministratorsTeam`, in ambiente Active Directory l'aggiornamento delle *Access Control List* non ha effetto immediato sulla sessione corrente, per via dell'immutabilità del gettone di accesso (o *Access Token*). Per l'invocazione dei processi di rigenerazione completa dello *Access Token* contenente i nuovi *Security Identifier* (o SID) di gruppo con l'aggiornamento delle ACL, si è eseguita la procedura di disconnessione della sessione, e successiva riconnessione.

Relativamente al comando `Set-Acl`, per ogni cartella è stata eseguita una sequenza di comandi, inclusiva del comando `Set-Acl`, simile alla seguente blocco di sequenze di comandi Powershell per la cartella `C:\EpicOrgData\SalesProcurement` della *Organizational Unit* "EpicCompany", creata per gli obiettivi del presente report:

```
$thisActiveDirectoryDomain = (Get-ADDomain).NetBIOSName; # Variabile di appoggio per il dominio della Active Directory
$ouFolderPath = "$(baseOuPath)\SalesProcurement"; $ouFolderAcl = Get-Acl -Path $ouFolderPath;
$ouFolderAcl.SetAccessRuleProtection($true, $false) # Disabilita l'ereditarietà dai padri e rimuove i permessi ereditati ($true, $fal

# Blocco di definizione delle ACL per il gruppo "Administrators"
$administratorsAclRule = New-Object System.Security.AccessControl.FileSystemAccessRule(
    "AdministratorsTeam",
    [System.Security.AccessControl.FileSystemRights]"FullControl",
    [System.Security.AccessControl.InheritanceFlags]"ContainerInherit, ObjectInherit", # Indici di ereditarietà (Inheritance flags)
    [System.Security.AccessControl.PropagationFlags]::None, #Indici di propagazione (Propagation flags)
    [System.Security.AccessControl.AccessControlType]::Allow
); $ouFolderAcl.AddAccessRule($administratorsAclRule);

# Blocco di definizione delle ACL per il gruppo "MarketingTeam"
$marketingAclRule = New-Object System.Security.AccessControl.FileSystemAccessRule(
    "$($thisActiveDirectoryDomain)\MarketingTeam",
    [System.Security.AccessControl.FileSystemRights]"FullControl",
    [System.Security.AccessControl.InheritanceFlags]"ContainerInherit, ObjectInherit", # Indici di ereditarietà (Inheritance flags)
    [System.Security.AccessControl.PropagationFlags]::None, #Indici di propagazione (Propagation flags)
    [System.Security.AccessControl.AccessControlType]::Allow
); $ouFolderAcl.AddAccessRule($marketingAclRule);

# Blocco di definizione delle ACL per il gruppo "DevTeam"
$devTeamAclRule = New-Object System.Security.AccessControl.FileSystemAccessRule(
    "$($thisActiveDirectoryDomain)\DevTeam",
    [System.Security.AccessControl.FileSystemRights]"FullControl",
    [System.Security.AccessControl.InheritanceFlags]"ContainerInherit, ObjectInherit", # Indici di ereditarietà (Inheritance flags)
    [System.Security.AccessControl.PropagationFlags]::None, #Indici di propagazione (Propagation flags)
    [System.Security.AccessControl.AccessControlType]::Deny
); $ouFolderAcl.AddAccessRule($devTeamAclRule);

# Blocco di definizione delle ACL per il gruppo "CyberSecOpsTeam"
$cyberSecOpsTeamAclRule = New-Object System.Security.AccessControl.FileSystemAccessRule(
    "$($thisActiveDirectoryDomain)\CyberSecOpsTeam",
    [System.Security.AccessControl.FileSystemRights]"FullControl",
    [System.Security.AccessControl.InheritanceFlags]"ContainerInherit, ObjectInherit", # Indici di ereditarietà (Inheritance flags)
    [System.Security.AccessControl.PropagationFlags]::None, #Indici di propagazione (Propagation flags)
    [System.Security.AccessControl.AccessControlType]::Deny
); $ouFolderAcl.AddAccessRule($cyberSecOpsTeamAclRule);

# Blocco di definizione delle ACL per il gruppo "RecruitingTeam"
$recruitingTeamAclRule = New-Object System.Security.AccessControl.FileSystemAccessRule(
    "$($thisActiveDirectoryDomain)\RecruitingTeam",
    [System.Security.AccessControl.FileSystemRights]"FullControl",
    [System.Security.AccessControl.InheritanceFlags]"ContainerInherit, ObjectInherit", # Indici di ereditarietà (Inheritance flags)
    [System.Security.AccessControl.PropagationFlags]::None, #Indici di propagazione (Propagation flags)
    [System.Security.AccessControl.AccessControlType]::Deny
); $ouFolderAcl.AddAccessRule($recruitingTeamAclRule);

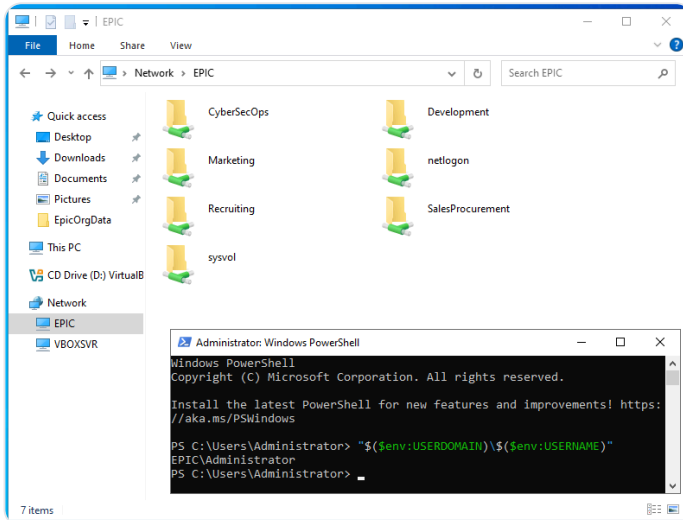
# Blocco di definizione delle ACL per il gruppo "RecruitingTeam"
$salesProcurementTeamAclRule = New-Object System.Security.AccessControl.FileSystemAccessRule(
    "$($thisActiveDirectoryDomain)\SalesProcurementTeam",
    [System.Security.AccessControl.FileSystemRights]"Read, Write, Delete, ListDirectory",
    [System.Security.AccessControl.InheritanceFlags]"ContainerInherit, ObjectInherit", # Indici di ereditarietà (Inheritance flags)
    [System.Security.AccessControl.PropagationFlags]::None, #Indici di propagazione (Propagation flags)
    [System.Security.AccessControl.AccessControlType]::Allow
); $ouFolderAcl.AddAccessRule($salesProcurementTeamAclRule);

Set-Acl -Path $ouFolderPath -AclObject $ouFolderAcl
```

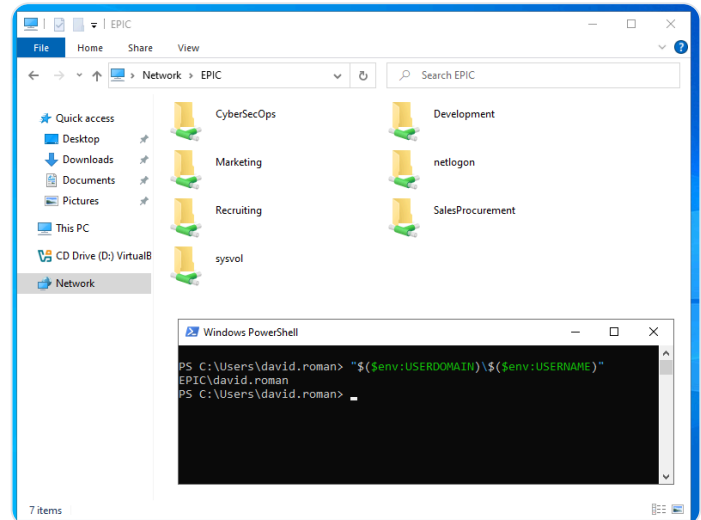
Relativamente ai percorsi del protocollo *Server Message Block* (SMB), sono definiti i seguenti percorsi remoti:

- `\\EPIC\Administrators$`, definito per il gruppo `AdministratorsTeam` in condivisione nascosta, punta al percorso `C:\EpicOrgData\Administrators`;
- `\\EPIC\Marketing`, definito per il gruppo `MarketingTeam`, punta al percorso `C:\EpicOrgData\Marketing`;
- `\\EPIC\Development`, definito per il gruppo `DevTeam`, punta al percorso `C:\EpicOrgData\Development`;
- `\\EPIC\CyberSecOps`, definito per il gruppo `CyberSecOpsTeam`, punta al percorso `C:\EpicOrgData\CyberSecOps`;
- `\\EPIC\Recruiting`, definito per il gruppo `RecruitingTeam`, punta al percorso `C:\EpicOrgData\Recruiting`;
- `\\EPIC\SalesProcurement`, definito per il gruppo `SalesProcurementTeam`, punta al percorso `C:\EpicOrgData\SalesProcurement`.

Per l'applicazione dei percorsi SMB sopra definiti è stato utilizzato il comando\funzione Powershell `New-SmbShare`



Finestra di *Windows Explorer* del percorso SMB `\\EPIC` visibile dall'account `Administrator` del gruppo `AdministratorsTeam`



Finestra di *Windows Explorer* del percorso SMB `\\EPIC` visibile dall'account `david.roman` del gruppo `MarketingTeam`